INFORMÁTICA FORENSE · GRUPO 2

RFC 3227 y Guía ACPO

Recolección, preservación y defensa de la evidencia digital: de la norma al dictamen pericial

Integrantes:
Johan Camilo Tamara
Natalia Forero Lozano
Laura Gutiérrez Torres
Ayda Castro Suárez

Bogotá, 30 de octubre de 2026

Ruta de la sustentación

01 **Contexto**

Origen, aplicabilidad y vigencia

02 **Núcleo técnico**

Principios, orden de volatilidad, ciclo

03 **Defensa de la prueba**

Custodia, hash y repetibilidad

04 **Caso DF-2026-017**

Aplicación y dictamen de admisibilidad

05 **Conclusiones**

Límites y valor para la organización

Dos marcos, dos preguntas distintas

IETF · BCP 55

RFC 3227

Guía para recolectar y archivar evidencia de un incidente de seguridad. Escrita para administradores de sistemas.

- Brezinski y Killalea, febrero de 2002
- Best Current Practice, sin reemplazo
- Responde: **qué recoger y en qué orden**

POLICÍA DEL REINO UNIDO

Guía ACPO v5

Buenas prácticas para la evidencia digital en todo su ciclo: planear, capturar, analizar, presentar.

- Finalizada en 2011, publicada en 2012
- ACPO es hoy el NPCC (2015); revisada y vigente en 2021
- Responde: **quién actúa y cómo responde**

Fuentes: rfc-editor.org (RFC 3227); Knowledge Hub, National Standards (estado de ACPO v5)

Aplicabilidad en Colombia

Necesidad pericial	Lo aporta el marco técnico	Lo exige la norma colombiana
Valor probatorio del dato	RFC 3227: evidencia admisible, auténtica, completa, confiable y creíble	Ley 527 de 1999, art. 11
Cadena de custodia	RFC 3227 §4.1; ACPO principio 3	Ley 906 de 2004, arts. 254-266
Tipificación del hecho	Hallazgos técnicos reproducibles	Ley 1273 de 2009 (arts. 269A a 269J)
Privacidad	RFC 3227 §2.3	Ley 1581 de 2012
Competencia del perito	ACPO principio 2	Idoneidad del perito en juicio oral

Ninguno de los dos marcos es ley en Colombia: su fuerza está en ser práctica reconocida que el juez puede verificar.

Los cuatro principios ACPO

Principio 1 · No alteración

Ninguna acción debe cambiar datos que luego puedan presentarse ante el tribunal.

Principio 2 · Competencia

Si hay que tocar el original, lo hace alguien competente que pueda explicar qué hizo y qué implica.

Principio 3 · Registro auditable

Todo proceso queda registrado para que un tercero independiente llegue al mismo resultado.

Principio 4 · Responsabilidad

Quien dirige la investigación responde por que se cumplan la ley y estos principios.

Ciclo de la guía: **Planear → Capturar → Analizar → Presentar**

RFC 3227: qué hacer y qué evitar

Principios guía (§2)

- Respetar la política de seguridad del sitio
- Capturar la imagen más fiel posible del sistema
- Tomar notas detalladas, con hora local y UTC
- Minimizar cambios en los datos
- Recolectar primero, analizar después
- Ir de lo más volátil a lo menos volátil

Acciones a evitar (§2.2)

- Apagar antes de recolectar lo volátil
- Confiar en los programas del sistema comprometido
- Ejecutar programas que cambien tiempos de acceso
- Desconectar la red sin prever borrados en cadena
- Aplicar herramientas que modifiquen la evidencia

Complementan: privacidad (§2.3), consideraciones legales (§2.4), recolección (§3), archivo y custodia (§4) y kit de herramientas (§5).

Orden de volatilidad: lo que se pierde primero, se recoge primero

1	Registros y caché de CPU	nanosegundos
2	RAM, procesos, rutas, ARP, estadísticas del kernel	segundos
3	Sistemas de archivos temporales	minutos
4	Disco	días
5	Registro remoto y monitoreo	según retención
6	Configuración física y topología	meses
7	Medios de archivo	años

Ciclo de la evidencia bajo ambos marcos

Identificar

Mandato, alcance, escena aislada y fotografiada, desfase del reloj

ACPO Planear

Recolectar

Volátil primero con kit confiable; luego imagen bit a bit con bloqueador

RFC §2.1, §3 · ACPO Capturar

Preservar

Hash dual, rotulado, sellado, custodia y copias de trabajo

RFC §4 · ACPO P1

Analizar

Solo sobre copias; cada paso registrado y repetible

ACPO Analizar, P3

Presentar

Dictamen con hechos, método, límites; perito que sustenta

ACPO Presentar, P2, P4

Punto de decisión clave: ¿equipo encendido? Si está apagado, no se enciende. Si está encendido y hay datos solo en memoria o cifrado activo, adquisición en vivo justificada por escrito.

Defensa de la prueba: integridad demostrable

Hash dual

SHA-256 y SHA3-256 sobre el original, la imagen y cada artefacto volátil. Dos familias distintas: una colisión simultánea es inviable en la práctica.

```
sha256sum /dev/sdb
openssl dgst -sha3-256 /dev/sdb
sha256sum evid01.dd
```

Ninguno de los dos marcos fija algoritmo; la Guía Lite lo exige.

Cadena de custodia

Campo	Contenido mínimo
Identificación	Caso, EMP, serial, ubicación
Integridad	Ambos hashes, herramienta, sello
Continuidad	Fecha, hora, quién entrega y recibe, motivo
Condiciones	Embalaje, almacenamiento, novedades

RFC 3227 §4.1 · Ley 906 de 2004, arts. 254-266

Repetibilidad: otro perito, el mismo resultado

Admisible

Obtenida conforme a la ley y al mandato

Auténtica

Vinculada al incidente y a su origen

Completa

Cuenta toda la historia, no una parte

Confiable

Sin dudas sobre cómo se obtuvo

Creíble

Comprensible para el juez

Criterios de evidencia según RFC 3227 §2.4

> Para que un tercero repita el trabajo, la bitácora registra en cada paso: **herramienta y versión, parámetros, hora, operador, hash antes y después**.
>
> Es el principio 3 de ACPO convertido en formato: sin registro, no hay repetibilidad; sin repetibilidad, la prueba se discute.

CASO DF-2026-017 · SIMULADO DE ALTA FIDELIDAD

Una cuenta de servicio olvidada, 4,7 GB exfiltrados y un cifrador que vivía solo en memoria

Hora (UTC-5)	Hecho
12-sep 23:41	VPN con svc_backup, cuenta no deshabilitada al retiro del exadministrador
13-sep 00:20	RDP a SRV-FS01 y salida de 4,7 GB hacia la nube durante 75 minutos
13-sep 01:52	PowerShell codificado inyecta un cifrador en memoria
13-sep 02:05	Borrado del registro de seguridad local (evento 1102)
13-sep 07:40	Técnico interno apaga SRV-FS02 para frenar el cifrado
13-sep 11:30	Llega el equipo pericial y aplica la Guía Lite

Empresa, personas, IP y hashes ficticios · detalle completo en el documento del caso

Tres dilemas, tres decisiones justificadas

VOLATILIDAD EXTREMA

Cifrador y clave solo en RAM

Captura en vivo con WinPmem desde kit de solo lectura; luego estado de red y procesos. Clave AES recuperada.

RFC §2.1 · ACPO P2

ANTIFORENSE

Logs borrados y fechas alteradas

Se usó el SIEM remoto que el atacante no alcanzó; tiempos de la MFT contrastados con NetFlow.

RFC §2.1, nivel 5

EVIDENCIA DAÑADA

SSD apagado y USB manipulada

No se reencendió el SSD; se declaró la pérdida por TRIM. La USB se adquirió tal cual y quedó como indicio de apoyo.

ACPO P1, P3

Dictamen: cuatro pruebas sólidas, una con reserva, una de apoyo

Evidencia	Dictamen	Fundamento
EV-01 RAM SRV-FS01	Sólida	Captura en vivo justificada, hash verificado
EV-02 Imagen RAID	Sólida	Bloqueador y hashes coincidentes
EV-04 SIEM, NetFlow, VPN	Sólida	Fuente independiente del sistema atacado
EV-03 Imagen SSD	Sólida, parcial	Espacio no asignado perdido por TRIM; límite declarado
EV-05 Portátil	Con reserva	Vacío de 6 h en custodia; sello intacto y hash coincidente
EV-06 USB	Solo apoyo	Abierta sin bloqueador antes de la entrega

Ninguna conclusión principal depende de EV-06: la exfiltración y el cifrado se acreditan con cuatro fuentes independientes.

Alcance y limitaciones

Lo que los marcos no cubren bien	Cómo lo resuelve la Guía Lite
Nube y SaaS: el RFC asume acceso físico al equipo	ISO/IEC 27037, logs del proveedor y solicitud formal de preservación
Móviles e IoT con cifrado por hardware	Aislamiento Faraday y herramientas especializadas, documentando el tipo de extracción
SSD, TRIM y cifrado de disco completo	Captura en vivo cuando es posible y límite declarado en el dictamen
Algoritmo hash no definido	SHA-256 + SHA3-256 obligatorios
Jurisdicción: ACPO responde al derecho británico	Validación con CPP, Ley 527 y Ley 1273

Valor estratégico de adoptarlos en la empresa

Pruebas que resisten el juicio

Evidencia admisible para denunciar, despedir con justa causa o reclamar a una aseguradora.

Primera respuesta sin daños

Un protocolo de una página para TI evita el error más caro: apagar o tocar lo que no se debe.

Responsables claros

ACPO P4 asigna un líder; la junta sabe quién responde por el proceso.

Bajo costo, alto retorno

Kit preparado, retención de logs y formación de dos funcionarios cuestan menos que perder una prueba.

Una evidencia vale lo que vale su método.

RFC 3227 dice qué recoger y en qué orden. ACPO dice quién lo hace y cómo responde. Juntos convierten un dato en prueba.

Preguntas del jurado